Id	AUDIT-2026-10-21-MyTradingBox	**Date**	2026-10-21
Type	audit	**Status**	open
Repo	MyTradingBox	**Author**	Claude
Stack	angular	**Findings**	critical: 0, high: 2, medium: 6, low: 22

MyTradingBox code audit — 2026-10-21

Summary

This is the fourth audit of MyTradingBox. It covers the 150 commits from `01dde7f` (the 2026-10-07 audit) up to `05765fa` (v0.2.93), and re-checks every finding still open from that audit.

The build is in good shape:

- 1,189 tests pass, up from 928.
- Line coverage rose from 61.2% to 67.5%.
- Lint is clean.
- The production build is still 484 kB initial.
- The half-written deploy (BUG-0006) is resolved.

But nothing from the last audit's fix-first list has been fixed:

1. **The leaked GitHub PAT (BUG-0001, Critical) is still publicly downloadable.**
2. `origin/07-2026wip` and `origin/eslint-branch` still exist with the full token.
3. The repo `MyTradingViewBV/MyTradingBox` is public.
4. Revoke the token and delete both branches today.
5. **BUG-0002 and BUG-0003 (drawings wiped or written under the wrong symbol) are still open.** They are now triggered on every tab return as well, because of the new resume reload (BUG-0012).
6. **The backend watchlist IDOR (N-SEC1) is still open.** This is its third audit.

New in this range:

- The new dashboard's Report tab asks every user for a GitHub PAT with Contents:write. It keeps the token in `localStorage` on the shared `github.io` origin (BUG-0010), keeps it after logout (BUG-0014), and commits screenshots to a public repo (BUG-0015).
- The `/overview` page calls admin-only endpoints for everyone, so non-admins get "Forbidden" toasts every minute (BUG-0011).

Severity	Count
Critical	0 new (1 carried over: BUG-0001)
High	2 new (3 carried over: BUG-0002, BUG-0003, N-SEC1)
Medium	6
Low	22

One feature is proposed (FEAT-0003). Carried-over findings keep their IDs and are listed under "Status of previous findings". They are not counted in the table above.

Scope

- **Repository / branch / commit:** MyTradingBox / `main` / `05765fa`. The working tree is clean.
- **Stack:**
- Angular 22.2.1 SPA in TypeScript, with NgRx and Vitest 4.1.

- Deployed to GitHub Pages.
- About 175 non-spec TypeScript files.
- The bundled rules cover C#, React and Delphi, not Angular. As in the earlier audits, the React/TypeScript rules (RE-*) were applied where they carry over, and Angular-specific checks were added on top: OnPush change detection, RxJS cleanup and guards.
- **Covered:**
- Every non-spec source file changed in `01dde7f..HEAD` (177 files, +18.5k/–3.7k lines), split into four areas: security and ops, chart core, MCB and watchlist, and dashboard and app shell.
- A secret scan of history since 2026-10-07 on all refs.
- The public gh-pages history, checked through the GitHub API because the local gh-pages clone is shallow.
- The backend controllers in `C:\repos\API` for N-SEC1 and the new admin endpoints.
- The rest of the codebase was sampled, not read line by line.
- **Commands run:**
- `npm run test:coverage`: 91 files and 1,189 tests, all passing. Coverage: statements 65.5%, branches 54.8%, functions 66.1%, lines 67.5%.
- `npm run lint`: clean.
- `ng build --configuration production`: OK, 483.6 kB initial / 132.6 kB transfer.
- `npm audit`: 4 vulnerabilities (3 high, 1 moderate), all in dev tooling (BUG-0029).
- **Excluded:** `node_modules/`, `dist/`, `coverage/`, `public/` static assets, `package-lock.json`, `*.scss`. There is no `.audit.yml`.

Findings

BUG-0010 · High · Report tab stores a GitHub PAT with Contents:write in `localStorage` on a shared origin

- **Rule:** RE-R10 (token storage), RE-R6
- **Location:**
- `src/app/components/dashboard/report-tab/github-report.ts:14, 93-107`
- `github-report.service.ts:58-95, 110-116`
- `src/assets/i18n/en.json:468`
- **Evidence:**

```
export const TOKEN_KEY = 'mtb.dashboard.githubToken';
...
localStorage.setItem(TOKEN_KEY, token.trim());
```

The UI asks for "a fine-grained token … with Issues and Contents: read & write". The service then calls `api.github.com` directly from the browser: it creates refs (`POST git/refs`) and writes files (`PUT contents/...`).

- **Impact:**
- A fine-grained token with Contents:write on this repo can push to `main` and `gh-pages`. It cannot be limited to one branch.
- The app is served from `mytradingviewbv.github.io`. Every other Pages project in the org shares that origin and its `localStorage`; `box2boxAngular` already has Pages enabled (N-SEC2).
- Any script running there, or any XSS in this app, can read the token and push to `gh-pages`, which means a persistent takeover of the site.

- This is the BUG-0001 risk again, now repeated for every user who connects a token.
- `connect-src https://api.github.com` was added to the CSP (`src/index.html:16`, `nginx.conf:24`), which gives injected script a new way to send data out.
- **Fix:** move issue creation to the backend (FEAT-0003). The old `github-issue.service.ts` already worked this way. If it must stay in the browser for now:
- Ask for Issues:write only, and upload screenshots through the backend.
- Keep the token in memory or `sessionStorage`.
- Show the tab to admins only.

BUG-0011 · High · Non-admins on `/overview` get a "Forbidden" toast every minute and an empty Bot health card

- **Rule:** RE-R8
- **Location:**
- `src/app/components/dashboard/overview-tab/overview-tab.component.ts:157-164`
- `src/app/modules/shared/auth/interceptors/error.interceptor.ts:16-19`
- API: `AiQueueController.cs:13` and `BotHeartbeatController.cs:14`, both `[Authorize(Roles = "Admin")]`
- **Evidence:**

```
this._settings.waitForExchangeId$()...subscribe((exchangeId) => this._heartbeats.load(exchangeId)); // not
gated
this._data.aiQueueCount()...subscribe((n) => this.aiQueue.set(n));                                    // not
gated
if (this.isAdmin()) { this._data.pendingNotifications()... }                                          // only
this one is gated
```

- **Impact:**
- `loadFast()` runs on `timer(0, 60_000)`. The dashboard is linked for every user: from the footer in web mode, and from a Settings row on mobile.
- Each run sends two requests that return 403 for a normal user. The global interceptor shows `ERROR.FORBIDDEN` for every 403.
- The Bot health card shows "No heartbeats".
- These 403s also replace the sticky reload toast (BUG-0017).
- **Fix:**
- Gate `_heartbeats.load` and `aiQueueCount` on `isAdmin()`, and hide the Bot health and Queues cards for non-admins.
- Optionally, make the interceptor only toast for `environment.apiUrl` requests.

BUG-0012 · Medium · Returning to the tab after 5 s resets zoom and pan and writes the drawings back

- **Rule:** RE-R9
- **Location:** `src/app/components/chart/chart-base.component.ts:1170-1193` (`onVisibilityChange`, `onPageShow`, `reloadAfterResume`), `:1934` (`clearScaleRanges()` in `onTimeframeChange`)
- **Evidence:**

```
private reloadAfterResume(): void {
  if (this.destroyed || !this.selectedTimeframe) return;
  this.ngZone.run(() => this.onTimeframeChange(this.selectedTimeframe));
}
```

- **Impact:**
- **Viewport lost:** a desktop user scrolls back three weeks to study a setup, switches browser tabs for 10 s and comes back. The chart has jumped back to the live edge at default zoom.
- **Write-back on every return:** the reload also re-runs the chart-state restore. That triggers the BUG-0003 auto-save each time (one `PUT ChartState`), and on `/chart` it re-sends `Drawings: "[]"` (BUG-0002). Both High data-loss bugs now trigger on every return to the tab.
- **Double reload:** a bfcache restore fires both `pageshow(persisted)` and `visibilitychange`, so the chart reloads twice.
- **Fix:**
- Give resume its own path that reloads candles and the stream but keeps the scale ranges and skips the chart-state reload.
- Dedupe the two events with a "resume in progress" flag.

BUG-0013 · Medium · Drawing edits made less than 1.5 s before leaving the page are lost

- **Rule:** RE-R8 / data loss
- **Location:** `chart-base.component.ts:1130-1143`. This code predates the range but was not reported before.
- **Evidence:**

```
this.drawingTools.drawings.pipe(debounceTime(1500), distinctUntilChanged(), takeUntil(this.destroy$))
```

`takeUntil` sits after `debounceTime`. On destroy, the pending value is dropped instead of saved.

- **Impact:** a user drags a TP line, then clicks a nav link (or reloads or closes the tab) within 1.5 s. The edit is never saved, and the old drawing is back on the next visit.
- **Fix:**
- Keep a `_saveDirty` flag and call `saveCurrentChartState()` from `ngOnDestroy` and `pagehide` when it is set.
- On `pagehide`, use `fetch(..., { keepalive: true })`.
- This belongs in the same chart-state persistence service as the BUG-0002/0003 fixes (FB-0003).

BUG-0014 · Medium · The GitHub token survives logout and is used by the next user on the device

- **Rule:** RE-R10
- **Location:** `report-tab.component.ts:75, 123-124`; `src/app/modules/shared/services/services/appService.ts:87-106` (`clearAllStates` / `logout`)
- **Evidence:**
- `logout()` clears the NgRx state and timers, but never removes `mtb.dashboard.githubToken`.
- The only `removeItem(TOKEN_KEY)` is the "forget" button.
- **Impact:** user B logs in on a shared device, opens `/overview?tab=report`, and creates issues and pushes commits with user A's GitHub identity.
- **Fix:** remove `TOKEN_KEY` in `clearAllStates()`, or key the token to the app user ID. FEAT-0003 removes the problem entirely.

BUG-0015 · Medium · Report screenshots and device details are committed permanently to a public repo

- **Rule:** privacy / information disclosure

- **Location:** `github-report.ts:11, 40, 57-71`; tab shown to all users in `dashboard.component.html:51`
- **Evidence:**
- Images are committed to branch `issue-images` and linked as `…/blob/issue-images/…?raw=true`. The comment at `:68` says this works "also for private repos", but `MyTradingViewBV/MyTradingBox` is public.
- The issue body includes `navigator.userAgent`, the UI mode and the version.
- **Impact:**
- Trading screenshots (balances, orders, watchlists) become world-readable.
- They stay in git history even after the issue is deleted.
- The `issue-images` branch does not exist yet, so nothing has leaked so far.
- **Fix:** send reports through the backend to a private destination (FEAT-0003). Until then, limit the tab to admins and warn in the UI that reports are public.

BUG-0016 · Medium · The dashboard's "today" events can be wrong, out of order, and in a different time base from the chart

- **Location:**
- `src/app/components/dashboard/dashboard-stats.ts:146-156`
- `overview-tab.component.html:173`
- API: `ForexCalendarEventsController.cs:40-41`
- **Evidence:**

```
.OrderByDescending(e => e.EventDate).ThenBy(e => e.EventTime)   // EventTime is free text, so this is a string sort
```

```
return (high.length ? high : todays).slice(0, max);   // template: {{ e.EventTime || '—' }}
```

- **Impact:**
- The string sort puts "10:00am" and "1:30pm" before "8:30am". On a day with more than five high-impact events, the earliest ones can be dropped.
- The chart's news overlay (`chart/utils/news-events.ts:56-64`) treats the event time as UTC. The dashboard picks "today" by the device's local date and shows the raw time, so a Dutch user sees "8:30am" for an event the chart places at 10:30.
- The card only loads on open or a manual refresh, so it goes stale after midnight.
- **Fix:**
- Use `newsEventWindow()` from `news-events.ts`.
- Filter on the local-day window and sort by start time.
- Format the time with `Intl.DateTimeFormat`.
- Reload the events in `loadFast`, or when the date changes.

BUG-0017 · Medium · Any later toast replaces the sticky "app is broken, Reload" toast

- **Location:** `src/app/components/shared/toast/toast.component.ts:354-363`; `src/app/helpers/sw-update.service.ts:182-185`
- **Evidence:** `clearTimeout(this._timer); this.current = msg;`. There is a single slot, and a `duration: 0` toast is not protected.
- **Impact:**
- The service-worker `unrecoverable` handler shows a toast that should stay until the user acts on it.

- The next toast replaces it: a 403 (BUG-0011), an alert, or the Plans "coming soon" toast. That toast then disappears after 4 s.
- The user loses the only Reload prompt while running a broken build.
- **Fix:** never replace a sticky toast that has an action with a non-sticky one. Queue the new toast or show it underneath. Also use `translate.get` for `APP_UPDATE.BROKEN`, so the raw key cannot appear before the translations load.

BUG-0018 · Low · Fixed volume profile writes: stale replies, wrong symbol, aborted on navigation

- **Location:** `chart-base.component.ts:5137-5160, 5219-5270, 5350-5380`
- **Evidence and impact:**
- **Stale reply:** `finishFixedProfileDrag` merges the server reply into the profile (`upsertProfile({ ...profile, ...saved })`), guarded only by `_fvpDragSeq`. `saveFixedProfilePanel` does not bump that sequence, so a drag reply that arrives after a rename brings the old name back until the next reload.
- **Wrong symbol:** the create panel reads `selectedSymbol` when the user saves, and stays open while a newly selected symbol is loading. Choosing a range on BTCUSDT, switching to ETHUSDT and pressing Opslaan creates an ETH profile with BTC's time range.
- **Aborted writes:** every create, update and delete uses `takeUntil(this.destroy$)`, so leaving the page right after a drag aborts the XHR. The code comment at the call site says "the write must reach the server".
- **Fix:**
- Bump the sequence on panel save, or keep a per-profile request sequence.
- Store the symbol and exchange in `FixedProfilePanel` when it opens, or close the panel in `beginSelectionChange()`.
- Subscribe to the write without `takeUntil`, and guard only the local-state callback with `if (this.destroyed) return`.

BUG-0019 · Low · Older long/short position drawings now show the wrong side

- **Location:** `src/app/components/chart/services/drawing-tools.plugin.ts:442`; the clamps in `applyPositionResize` (around `chart-base:2960`) and `applyPositionEdit` (around `:590`)
- **Evidence:** `const isLong = d.type === 'long-position';`. Before this range, the side was inferred from geometry (`tpPrice > entryPrice`).
- **Impact:**
- Positions saved before this range could have TP below entry under `type: 'long-position'`.
- They now show as Long with a negative target %.
- The first handle drag clamps TP to `entry + gap`, which collapses the profit zone.
- **Fix:** normalise old positions in `setDrawings`: derive `type` from the geometry, or swap TP and SL.

BUG-0020 · Low · The chart's news calendar request is not tied to the component and never refreshes

- **Location:** `chart-base.component.ts:865-880`
- **Evidence:** `this.marketService.getForexCalendarEvents().subscribe({ next: (events) => { ...; this.applyNewsDataset(); } })` has no `takeUntil`.
- **Impact:**
- The callback can run `safeUpdateDatasets` after the component is destroyed.
- The events are cached for the page's whole life, so on a chart left open the "Actual" values and next month's events never appear.

- **Fix:** add `takeUntil(this.destroy$)`, and expire the cache after about 30 minutes or when the month changes.

BUG-0021 · Low · Chunk-load recovery reloads on every load when `sessionStorage` is unavailable

- **Location:** `src/app/helpers/chunk-load-recovery.ts:29-44`
- **Evidence:**
- When `safeSessionStorage()` returns `null`, `storage?.getItem` gives `undefined`, `last` becomes 0, and the guard is skipped.
- The `catch` only covers storage that throws, not storage that is missing.
- **Impact:**
- With storage blocked (some privacy modes or sandboxed webviews), a chunk that is really missing reloads the page forever.
- Even with storage, the 30 s window is shorter than GitHub Pages' roughly 10-minute `index.html` cache, so stale-index reloads can repeat for minutes without telling the user.
- **Fix:**
- When storage is null, fall back to a module-level flag or a `?reloaded=1` marker.
- Add a cache-busting query to the reload URL.
- Show the reload toast when the guard blocks a reload.

BUG-0022 · Low · Flow forecast does not filter null or invalid candles in two paths

- **Location:** `src/app/components/watchlist/flow/flow-forecast.ts:136-151, 284-293`
- **Evidence:**

```
const candles1h = input.candles['1h'] || [];
const history = historySource.slice(-24).map((c) => c.Close)
```

`scoreTimeframe` (`:171-173`) filters with `c?.Close`, so null rows are expected. These two paths use the raw array instead.

- **Impact:**
- A null row makes `c.Close` throw inside the subscriber at `watchlist.ts:646`, and that coin never gets a forecast.
- A null `High` or `Low` makes the ATR `NaN`. `NaN || …` then silently falls back to the ATR of a different timeframe.
- **Fix:** filter the candles once at the top of `computeFlowForecast` (finite open, high, low and close) and use the filtered list everywhere.

BUG-0023 · Low · The MCB auto-fit scans every point on every update, including each frame of a pan

- **Location:** `src/app/components/market-cipher-b-chart/mcb-panel.component.ts:310-336`, called from `afterBuildTicks`, with `update('none')` per rAF at `:1337-1345`
- **Impact:** around 10 datasets × up to 1,000 points are scanned in full each frame during a linked pan, even though only the visible window matters.
- **Fix:** the data is sorted by x, so binary-search the `[xMin, xMax]` window per dataset, or cache the result by `(xMin, xMax, data version)`.

BUG-0024 · Low · An expired stored GitHub token shows as "Connected", and its error is hidden

- **Location:** `report-tab.component.ts:123-124, 222-225`; `report-tab.component.html:114-146`

- **Evidence:** the startup `verifyToken(token, false)` sets `tokenError`. But `tokenError` is only rendered inside `@if (vm.showTokenForm)`, which is false while a token is stored.
- **Impact:** the user writes the whole report and only sees the 401 after pressing Create. The `describeGithubError` messages (`github-report.service.ts:117-136`) are also hard-coded English.
- **Fix:** on a 401 at startup, clear the token or open the form, and render `tokenError` outside the form branch.

BUG-0025 · Low · The Tests tab can show "NaN"

- **Location:** `src/app/components/dashboard/tests-tab/tests-tab.component.ts:43-47, 60-62`
- **Evidence:** `num.format(totals.smoke)` on fields read straight from `test-counts.json`.
- **Impact:** a JSON file from an older or partial generator shows "NaN". The words `unit`, `smoke` and `e2e` are also not translated.
- **Fix:** use `num.format(totals.x ?? 0)` and translation keys.

BUG-0026 · Low · The Timeframes symbol picker can show a different symbol than the tiles

- **Location:** `timeframes-tab.component.ts:44, 80-83`; `timeframes-tab.component.html:136-138`
- **Impact:** a symbol restored from `mtb.dashboard.timeframeSymbol` that is no longer in `symbols()` (for example after switching exchange) matches no `<option>`. The select then shows BTCUSDT while the tiles load the stored symbol.
- **Fix:** after the symbol list loads, fall back to the default when the stored symbol is missing.

BUG-0027 · Low · One failed heartbeat fetch empties the shared heartbeat list

- **Location:** `src/app/components/admin/services/heartbeat.service.ts:65-68`
- **Impact:**
- A single transient error, or the 403s from BUG-0011, clears the root-singleton `items`. Admin and Dashboard then show "No heartbeats" instead of the last known state.
- `data.map` also throws if the API returns `null`.
- **Fix:** keep the previous items on error, and guard with `Array.isArray(data)`.

BUG-0028 · Low · Dead and inaccessible controls in login and settings

- **Rule:** RE-O3
- **Location:** `src/app/components/login/login.component.html:255-262`; `src/app/components/settings/settings.component.html:169`
- **Evidence:**
- Login: `<button type="button" class="link terms-link">` for Terms and Privacy, with no `(click)` and no href.
- Settings: `<div class="item-row glass hoverable dashboard-row" routerLink="/overview">`.
- **Impact:**
- The Terms and Privacy buttons do nothing.
- The Dashboard row in Settings cannot be reached with the keyboard, and screen readers don't announce it as a link.
- **Fix:** link the Terms and Privacy buttons to real pages, or remove them. Use `<a routerLink>` for the Settings row.

BUG-0029 · Low · `npm audit` reports 4 vulnerabilities in dev tooling

- **Location:** `package.json` / lockfile: `vite@8.3.0` (through `@angular/build` 22.2.1 and vitest) and `@modelcontextprotocol/server` 2.0–2.2 (through `@angular/cli`)

- **Evidence:** 3 high and 1 moderate:
- `launch-editor` command execution and escaping issues (GHSA-698v-4r3x-3vcv, GHSA-r825-w8mm-5pxw, GHSA-587h-7wmj-h5pm).
- MCP SDK transport and auth issues (GHSA-jm63-cq47-j5jp, GHSA-46jr-4wx8-v453, GHSA-rvq5-wwqv-78pq).
- **Impact:** neither package ships in the production bundle. The risk is limited to the developer machine while `ng serve` or the CLI's MCP server is running.
- **Fix:** update `@angular/build` and `@angular/cli` to the next patch that pulls in fixed versions. Don't run `npm audit fix --force`: it downgrades `@angular/build`.

FEAT-0003 · Suggested feature · Server-side issue reporting

- **Location:** `src/app/components/dashboard/report-tab/**`, API repo
- **Why:** BUG-0010, BUG-0014 and BUG-0015 all come from the browser holding a GitHub token with write access and sending reports to a public repo.
- **Proposal:**
- Add an API endpoint (`POST api/Feedback`) that accepts the text and screenshots from a logged-in user.
- Store the screenshots privately on the backend.
- Create the issue with a GitHub App installation token limited to Issues on a private repo, or on this repo without attaching images.
- The Report tab then needs no token, no `api.github.com` in the CSP, and no Contents permission.

FB-0007 · Low · Flow forecast counts the still-forming candle as a closed candle

- **Location:** `flow-forecast.ts:47, 176-181` (`valid.slice(-3).map(candleDir)` and the EMAs)
- **Suggestion:**
- `getCandles` returns the live bar last; `watchlist-flow.component.ts:99` and `chart-base:2085` treat it that way.
- Right after a new bar opens, an almost empty doji counts towards the "last 3 closed candles", and the forecast can flicker.
- Drop the last candle before scoring, or correct the doc comment.

FB-0008 · Low · MCB vertical lines are hit-tested with a different x mapping than they are drawn with

- **Location:**
- Drawn: `mcb-panel.component.ts:461` (`sharedTimeX`).
- Hit-tested and dragged: `mcb-drawing-edit.ts:99, 136-151` (the pane's own x scale).
- **Suggestion:** if the two plots ever differ in width or offset, the line you see and the spot you can grab are apart. This was not confirmed at runtime. Pass the same `verticalLineX` mapping into `hitTestMcbDrawing` and `draggedMcbPoints`.

FB-0009 · Low · The MCB auto y-range ignores drawings on the pane

- **Location:** `mcb-panel.component.ts:310-336, 446-455`
- **Suggestion:** a horizontal line drawn at +80 goes off-screen when the data stays within ±50, and can't be reselected without dragging the axis. Include the y values of `paneDrawings('mcb')` in the fit, or document this as intended.

FB-0010 · Low · Flow candle polling load, and a cache that never shrinks

- **Location:** `watchlist.ts:609-670`; `chart.service.ts:198` (the `_t` cache-buster)
- **Suggestion:**

- Each stale coin makes 3 uncached `getCandles` calls every 3 minutes, so 30 coins is about 90 requests per cycle.
- The `flowCandles` Map never evicts symbols that were removed from the watchlist.
- Evict keys that are no longer in `userSymbols`, and consider one backend call that returns all three timeframes.

FB-0011 · Low · Fixed volume profiles with no candles in view leave invisible hit strips

- **Location:** `fixed-volume-profile.plugin.ts:79-93`; `fixed-volume-profile-layer.service.ts:198`
- **Suggestion:**
- With `result == null`, the geometry spans the full chart height with 8 px hit edges, and nothing is drawn because the idle fill is disabled ("TEMP").
- A profile built on 1m and viewed on 1d therefore has two invisible 16 px strips that grab the pointer instead of panning.
- Add no hit geometry when there is no result.
- Show a "partial data" hint when the range starts before the loaded history.

FB-0012 · Low · Allocations per frame and per event in the draw and hit paths

- **Rule:** RE-O2
- **Location:**
- `drawing-tools.service.ts` `paneDrawings()` filters on every call. It runs about 10 times per `mousemove` (`chart-base:2709-3090`) and on every draw.
- `chart-plugins.ts:125` `formatPriceText` calls `toLocaleString('en-US', {…})`, which builds a new `Intl.NumberFormat` per call, for every tick, crosshair and legend value on every frame.
- `chart-plugins.ts:1122` uses `points.indexOf(candle)`, which is O(n) per frame.
- From N-CQ7: allocating getters remain at `chart-base:912` (`legendTitle`), `:4262` and `:5048`.
- **Suggestion:**
- Cache `paneDrawings` per `drawings$` emission.
- Memoise one `NumberFormat` per decimal count.
- Have `findCandleAt` return the index.

FB-0013 · Low · Smaller chart items

- **Location and suggestion:**
- `chart.service.ts:183`: the `exchangeIdOverride` parameter is never passed. Remove it.
- `system-status.component.ts:75-87`: polls every 60 s while the tab is hidden. Pause it on `visibilitychange`.
- `chart-indicators.service.ts:227` with `chart-plugins.ts:588`: anchored glyphs on candles near the top or bottom edge may be pushed out of `chartArea` and dropped. Not verified at runtime.
- Delete and Escape do nothing for a selected fixed volume profile, and Escape does not close the panel.

FB-0014 · Low · `.mcp.json` runs an unpinned `npx @playwright/mcp@latest`

- **Location:** `.mcp.json:4` (a new committed file)
- **Suggestion:** this is the same class as N-SEC8. Pin an exact version, or add it to devDependencies and run it with `npx --no-install`.

FB-0015 · Low · The previous audit report contains a prefix of the leaked token

- **Location:** `audits/2026/W41/audits/2026-10-07_MyTradingBox_audit.md:74` and its PDF, on `main` of a public repo
- **Suggestion:**
- The prefix is not usable on its own, but secret scanners will flag it, and it points readers to the token in history.
- Redact it to `github_pat_11CB…` and regenerate the PDF.
- This report uses the short form throughout.
- Also consider whether audit reports that describe unfixed vulnerabilities should be committed to a public repo at all.

FB-0016 · Low · Dashboard polish

- **Location and suggestion:**
- `footer.component.html:51`: the Dashboard button has no `[class.active]`, so web users on `/overview` see no highlighted item.
- `en.json:247` and `nl.json:247`: `SETTINGS.FEEDBACK` is unused since the github-feedback component was removed.

Status of previous findings

Re-checked against `05765fa`.

ID	Finding	Status today	Evidence
BUG-0001	**GitHub PAT leaked**	**Still open (Critical)**	`origin/07-2026wip` (`cf25842`) and `origin/eslint-branch` (`620cc7b`) still exist and hold the full token at `src/environments/environment*.ts:14` and `docs/githubbot.md:1`. The repo is public and the raw file URL serves the token. gh-pages history was not rewritten (`3a53598...gh-pages` is ahead 83, behind 0). It was not checked whether the token itself has been revoked.
BUG-0002	**`/chart` wipes saved drawings**	**Still open (High), triggered more often**	`chart-component.ts:99-102` still calls `setDrawings([])`, with no save override or persist flag. BUG-0012 now re-triggers it on every tab return.
BUG-0003	**Auto-save stores drawings under another symbol**	**Still open (High), triggered more often**	`_restoringChartState` is still only true while the restore runs synchronously (`chart-base:5430-5437`). The save reads `selectedSymbol` when it fires (`:5398-5414`). BUG-0012 adds a restore and write-back on every tab return.
N-SEC1	**Backend watchlist IDOR**	**Still open (High)**, third audit	`API/BotAPI/Controllers/UserSymbolsController.cs:339-348` has not changed since 2026-04-05. `ChartStateController` already has a `ResolveUserId` pattern to copy.
BUG-0004	Security subjects in release notes	Still open	`release-notes.mock.json:1117,1121,1125`, live on gh-pages. The generator filter is unchanged (`generate-release-notes-mock.js:75`).
BUG-0005	Divergence cache / out-of-order loads	Still open	`divergencesCacheFresh` (`chart-base:4693-4698`) still compares only `lastX`, and `loadDivergences` (`:4700-4728`) still has no request guard.
BUG-0006	Half-written deploy	**Fixed**	The tree is clean. The 0.2.93 entries in `RELEASE_LOG.md` match `origin/gh-pages` (`7ad349c`), and `version.json` matches too.
BUG-0007	Dev environment uses prod API	Still open	`src/environments/environment.ts:6-7`
BUG-0008	Delete/Escape leaves the OnPush view stale	Still open	`chart-base:1281-1298` has no `markForCheck()`.

ID	Finding	Status today	Evidence
BUG-0009	Locked drawings can be deleted	Still open	None of the delete paths checks `isLocked`: `chart-base:1291`, `drawing-toolbox.component.ts:793`, `drawing-tools.service.ts:336`.
FEAT-0001	CI on all branches with a history scan	Not started	`.github/workflows/ci.yml` has not changed since `01dde7f`.
FEAT-0002	Atomic deploy	Not started	`package.json:26`: still bumps the version before building, `angular-cli-ghpages` is still unpinned, and there is no ancestor or version guard.
FB-0001	Lock in zero `any` and the coverage gains	Still open	`no-explicit-any: "warn"`; no `--max-warnings`; thresholds are still 45/30/47/46, against actual 65.5/54.8/66.1/67.5.
FB-0003	`chart-base` keeps growing	**Worse**	5,444 lines (was 4,744), with 39 empty `catch {}` blocks (was 38). Persistence is still not extracted.
FB-0004	Old fibs miss the 0.886 level	Still open	`drawing-tools.service.ts:345-347`
FB-0005	Push `icon`/`badge` URLs	Still open	`custom-sw.js` has not changed.
FB-0006	Leftovers from the chart-page removal	Still open	`docs/DOCUMENTATION_STATUS.md:11`; `chart-component.ts:22`
N-SEC2	Shared `github.io` origin	Still open, **worse**	It now also holds the GitHub PAT (BUG-0010).
N-SEC3 – N-SEC10	Clickjacking, localhost in CSP, `'unknown-user'`, logout limits, interceptor prefix check, unpinned publish tool, `?? 1` fallback, unencoded URLs	Still open	Mostly unchanged. The CSP gained `api.alternative.me` and `api.github.com`. `'unknown-user'` is now at `chart.service.ts:644,689`. The new `getFixedVolumeProfiles` (`:273`) uses the `?? 1` path through `getExchangeId$()`. The unencoded `userId` is now at `user-symbols.service.ts:102,121,132`.
N-CQ2	add-symbol ticker/interval leak	Still open	`add-symbol.component.ts:173-222`
N-CQ4	Dead code	Partially fixed	The watchlist delegates are gone. The unused `getSymbolIcon()` remains (`chart-base:761`).
N-CQ5	`resolveIconUrl` duplicated	Still open	Three copies: `alerts-settings.component.ts:48`, `add-symbol.component.ts:147`, `watchlist.ts:131`
N-CQ10	`.toPromise()` and static cache	Still open	`admin.component.ts:280`, `version.service.ts:24,42`, `watchlist.ts:257`
N-CQ11	Ungated `console.*` calls	Still open	99 (was 100)
N-OPS4	Two version numbers	Still open	0.2.93 against 0.1.249. The `#{Build.BuildNumber}#` token is still at `environment*.ts:5`.

Areas without findings

- **XSS sinks:** no `innerHTML`, `bypassSecurityTrust*`, `insertAdjacentHTML`, `document.write`, `eval` or `new Function` in non-spec `src/`.
- **New links:** the new `[href]` and `window.open` calls use fixed prefixes with `URLSearchParams` and `noopener`.
- **Secrets:** the secret scan of all refs since 2026-10-07 is clean. The new `github_pat_` hits are placeholders and spec strings. `e2e/.auth/user.json` is gitignored and was never committed.
- **Routes:** every new route has `authGuard`. `/plans` is public on purpose and makes no HTTP calls.

- **New backend endpoints:** `FixedVolumeProfiles`, `AiQueue` and `BotHeartbeat` are `[Authorize(Roles="Admin")]` on the server.
- **Third-party calls:** CoinGecko, alternative.me and GitHub calls carry no app JWT. The service worker caches only the public market URLs.
- **CI:** actions are pinned by SHA, the workflow has `contents: read`, and the gitleaks download is checksum-verified.
- **Persistence meta-reducer:** only two boolean flags were added to the allow-list.
- **Fixed volume profile math:** row distribution, POC and the 70% value-area expansion are correct. The cache key covers live ticks, history prepends and timeframe changes.
- **Exchange stream composite seed:** staleness is checked at every async step, and the gap and bucket-end handling is correct. No reconnect storm was introduced.
- **Volume and news plugins:** both draw only the visible slice, and the news windowing uses binary search.
- **Chart lifecycle:** listeners, ResizeObserver, rAF, countdown and signal timers are all cleaned up in `ngOnDestroy`.
- **MCB trendlines:** the polling timer is cleaned up. The stale-response guard and context-key checks are correct. The math guards division by zero and non-finite values.
- **MCB panel:** pen, drag and pan listeners are removed, `touchcancel` is handled, and the rAF is cancelled.
- **Watchlist flow:** OnPush with new references on every update, so no store mutation. Zero spans are guarded, and `markForCheck` runs after each async update.
- **Dashboard state:** signal-based view models, `takeUntilDestroyed` everywhere, and `catchError` on every data call. The statistics math guards division by zero.
- **Dashboard tabs:** they follow the WAI-ARIA tabs pattern.
- **i18n:** all 270 keys used by the new UI exist in both `en.json` and `nl.json`.
- **Service-worker update:** no reload loop; `VERSION_READY` leads to one activate-and-reload.
- **Admin deep links:** the `?section=` parameter is validated.

Recommended next steps

1 **Today:**

2 Revoke the GitHub PAT, delete `origin/07-2026wip` and `origin/eslint-branch`, and purge the token from gh-pages history (BUG-0001).

3 Hide the Report tab for non-admins until FEAT-0003 is done (BUG-0010, BUG-0014, BUG-0015).

4 **Before the next deploy:**

5 Gate the admin calls on `/overview` (BUG-0011).

6 Fix BUG-0002 and BUG-0003, and make resume keep the viewport and skip the chart-state reload (BUG-0012). Each needs a regression spec that advances the 1.5 s debounce timer.

7 **API repo:**

8 Scope `UserSymbols/{userId}/profile` to the caller (N-SEC1, third audit).

9 Build the feedback endpoint (FEAT-0003).

10 **This week:**

11 BUG-0013 (flush on leave), BUG-0016, BUG-0017.

12 The remaining low bugs from the last audit: BUG-0004, BUG-0005, BUG-0007, BUG-0008, BUG-0009.

13 FB-0015 (redact the token prefix).

14 **Plan:**

15 Extract chart-state persistence from `chart-base` (FB-0003). BUG-0002, BUG-0003, BUG-0012 and BUG-0013 would then all be fixed in one place.

16 Then FEAT-0001 and FEAT-0002, and the low items as their files are touched.